Ace Tomato Company

Threat Hunting Report

Prepared by: Francis Espiritu, Rei Thao, Minh Huy Tran

Table of Contents

Executive Summary....2
Scope and Methodology....2
Discovered Vulnerabilities and Threats....4
Risk Assessment....7
MITRE ATT&CK Mapping....8
Recommendations....9
Appendices....10

Executive Summary

A threat hunting exercise was performed from August 26th, 2025 to December 3rd, 2025 for the Ace Tomato Company. Several vulnerabilities were discovered and in addition, several active security events were observed. Indicators of compromise include remote account modification/creation, privilege elevation, malicious service creation/modification, attempts of persistence, shellshock attempts, and unauthorized account logon. Two domain controllers showed signs of compromise, with the traffic originating from the following IP addresses: 10.0.0.1, 10.0.0.2, and 10.0.0.200. Similarly, an account with elevated permissions, "Administrator" showed high signs of compromise. The organization faces significant risk of data exfiltration, privilege escalation, and lateral movement without immediate remediation.

Scope and Methodology

Systems/Assets Reviewed:

A total of six systems and assets were reviewed during the threat hunt. These included two domain controllers, DC1.ace.tomato (10.0.0.1) and DC2.ace.tomato (10.0.0.2), as well as two workstation endpoints, DESKTOP-QLMT00M (10.0.0.7) and WIN-4LFGOP8O9MH. The environment also contained a web server at 10.0.0.42, listed as a LAMP system exhibiting Shellshock behavior, and a foreign, unknown Kali Linux host at 10.0.0.200.

- DC1.ace.tomato
    - 10.0.0.1
- DC2.ace.tomato
    - 10.0.0.2
- DESKTOP-QLMT00M
    - 10.0.0.7
- WIN-4LFGOP8O9MH
- Web server with Shellshock exposure - LAMP
    - 10.0.0.42

```
group2@jumphost:~$ curl 10.0.0.42
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Ace Tomato Company</title>
    <script src="https://cdn.tailwindcss.com"></script>
    <style>
        pre { white-space: pre-wrap; font-size: 0.6rem; line-height: 1; }
        @media (min-width: 768px) { pre { font-size: 0.8rem; } }
    </style>
</head>
<body class="bg-gray-800 text-white font-mono">
    <!-- Navigation -->
    <nav class="bg-red-700 text-white p-4 sticky top-0 z-10">
        <div class="container mx-auto flex flex-col sm:flex-row justify-between items-center">
            <h1 class="text-2xl font-bold mb-2 sm:mb-0">Ace Tomato Company</h1>
            <ul class="flex space-x-6">
                <li><a href="#home" class="hover:underline">Home</a></li>
                <li><a href="#about" class="hover:underline">About</a></li>
                <li><a href="#products" class="hover:underline">Products</a></li>
                <li><a href="#contact" class="hover:underline">Contact</a></li>
            </ul>
        </div>
    </nav>

    <!-- Hero Section -->
    <section id="home" class="bg-gray-900 py-16">
        <div class="container mx-auto px-4 text-center">
            <pre class="text-red-400 mx-auto mb-4">
```

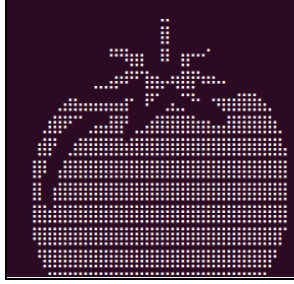

Figure 1.1

- Unknown Kali Linux host
    - 10.0.0.200

Tools and Techniques Used:

The threat hunt deployed a combination of tools and techniques used to identify malicious behavior across the company's network. Most observations were noted through the Wazuh SIEM, which served as an important pillar in log collection, correlation, and alert. Sysmon acted as an endpoint detection and response (EDR) system, offering information such as process creation, file modifications, and network connections. The MITRE ATT&CK framework was used as a conceptual framework for mapping observed activity to known behaviors. Together, these tools allowed for in-depth analysis and threat classification and recognition in the environment.

Within the Wazuh SIEM, filters ranging from sorting by agent IP address/name and severity scoring were created and used. Once the suspicious actors were identified, filters within the Wazuh allowed the team to pinpoint relative activity and access points. Furthermore, the custom filters allowed the team to follow a flow of events from the initial observations made to connect them to deeper, more concrete evidence of attacks and compromise.

- Wazuh SIEM

- Sysmon (EDR)

Framework References:

This investigation was conducted under the MITRE ATT&CK Framework, which helped map observed adversary behaviors to known tactics and techniques, and the NIST Cybersecurity Framework (CSF), which provided structure and workflow in identifying, protecting, detecting, responding to, and recovering data and events.

Discovered Vulnerabilities and Threats

Finding I — User-specific:

ID's — Windows Event:

- 4624 - An account was logged on
- 4634 - An account was logged off
- 4737 - A member was removed from a security-enabled global/local group
- 4728 - A member was added to a global group

Description:

Account manipulation involving privileged groups. The "administrator" account was removed from privileged groups after "ANONYMOUS LOGON" was added to Schema Admins and Enterprise Admins by the administrator account. "ANONYMOUS LOGON" added to Schema Admin and Enterprise Admin Groups. Both events are highly suspicious as administrator accounts should not be removed from any of the listed groups. The "ANONYMOUS LOGON" account should not be added to the groups with such high-level permissions as well. This points to an attacker creating persistence and defense evasion. They are most likely attempting to remove options that sys. admins may take to remove their presence from the devices. They may have gained access through malicious services and/or exploitation of the domain controllers. With the account they created, they may not perform almost anything that they'd like.

Affected Assets:

- Accounts:
  - Administrator
  - ANONYMOUS LOGON
- Systems
  - DC1.ace.tomato
  - DC2.ace.tomato

Discovery Method:

- Wazuh SIEM log review of group modification events.

Evidence:

- Windows Event Logs showing group policy modification and unauthorized account changes.

"A security-enabled universal group was changed.

Subject:
Security ID:S-1-5-7
Account Name:ANONYMOUS LOGON
Account Domain:NT AUTHORITY
Logon ID:0x3E6

Group:
Security ID:S-1-5-21-718747258-2643838839-2628826668-519
Group Name:Enterprise Admins
Group Domain:ACE

Changed Attributes:
SAM Account Name:-
SID History:-

Additional Information:
Privileges:-"

Figure 2.1

"A security-enabled universal group was changed.

Subject:
Security ID:S-1-5-7
Account Name:ANONYMOUS LOGON
Account Domain:NT AUTHORITY
Logon ID:0x3E6

Group:
Security ID:S-1-5-21-718747258-2643838839-2628826668-518
Group Name:Schema Admins
Group Domain:ACE

Changed Attributes:
SAM Account Name:-
SID History:-

Additional Information:
Privileges:-"

Figure 2.2

Finding II — Service/Application-specific:

ID's — Windows Event:

- 7045 - A new service has been installed on the system
- 1001 - Windows Error Reporting

Description:

A total of 14 unauthorized Windows services were created across the Company's two domain controllers. Twelve instances originate from DC1 with two instances coming from DC2. Each service had a randomized 4-5 character name, which is a common tactic used by threat actors attempting to blend into legitimate system processes. Similarly, an executable was observed exhibiting strange behavior on DC1. A "win32calc.exe" was being regularly crashed and auto-started.

All services were configured to run under the LocalSystem account, the highest privilege level available on Windows hosts. This level of privilege allows full control over system functions, registry operations, and security configurations. The frequency and proximity of events suggests automated deployment, likely through a compromised account or remote command execution tool. These details strongly indicate persistence mechanisms installed by an attacker and/or possible lateral movement from a previously compromised asset. Credibility of a compromise is supported by the earlier findings of account manipulation involving the "ANONYMOUS LOGON" account and creation of new accounts with elevated permissions and suspicious logon activity on domain controllers.

Affected Assets:

- Any data on or connections to these machines are at risk
    - DC1 - 10.0.0.1
    - DC2 - 10.0.0.2

Discovery Method:

- Wazuh service creation, crash, and startup alerts
    - Event ID 7045 logs indicating installation of unknown services
- Sysmon events showing service execution and startup (auto)

Evidence:

- Windows Event Logs showing multiple, consecutive creation of services and force crash/autostart of “win32calc.exe”

"A service was installed in the system. Service Name: JvRs Service File Name: %systemroot%\MDZxvkpU.exe Service Type: user mode service Service Start Type: demand start Service Account: LocalSystem"	New Windows Service Created to start from windows root path. Suspicious event as the binary may have been dropped using Windows Admin Shares.
"A service was installed in the system. Service Name: mcnd Service File Name: %systemroot%\WygTBmkm.exe Service Type: user mode service Service Start Type: demand start Service Account: LocalSystem"	New Windows Service Created to start from windows root path. Suspicious event as the binary may have been dropped using Windows Admin Shares.
"A service was installed in the system. Service Name: iUzi Service File Name: %systemroot%\bRnDWVnF.exe Service Type: user mode service Service Start Type: demand start Service Account: LocalSystem"	New Windows Service Created to start from windows root path. Suspicious event as the binary may have been dropped using Windows Admin Shares.

Figure 2.3 (above)

"Faulting application name: win32calc.exe, version: 10.0.20348.143, time stamp: 0xec85ee15 Faulting module name: win32calc.exe, version: 10.0.20348.143, time stamp: 0xec85ee15 Exception code: 0xc0000005 Fault offset: 0x0000000000037a50 Faulting process id: 0x760 Faulting application start time: 0x01dc3d8b4140862e Faulting application path: C:\Windows\System32\win32calc.exe Faulting module path: C:\Windows\System32\win32calc.exe Report Id: cc6f91c7-2193-45ea-a1b4-75f4ebcf89e2 Faulting package full name: Faulting package-relative application ID: "
"Fault bucket , type 0 Event Name: APPCRASH Response: Not available Cab Id: 0 Problem signature: P1: win32calc.exe P2: 10.0.20348.143 P3: ec85ee15 P4: win32calc.exe P5: 10.0.20348.143 P6: ec85ee15 P7: c0000005 P8: 0000000000037a50 P9: P10: Attached files: \\?\C:\ProgramData\Microsoft\Windows\WER\Temp\WER.685bf80a-ccc2-48de-90ba-e4a3cea2014c.tmp.WERInternalMetadata.xml These files may be available here: \\?\C:\ProgramData\Microsoft\Windows\WER\ReportQueue\AppCrash_win32calc.exe_adedefe5dc882f66ca6ea39f5f2e42a215b83bfa_8ec6bf7 Analysis symbol: Rechecking for solution: 0 Report Id: 4d529975-af7f-4b58-8f4f-4e6a82114c78 Report Status: 100 Hashed bucket: Cab Guid: 0"

Figure 2.4 (above)

Finding III — LAMP-specific:

ID — Web Server:

- 403 - Forbidden

Description:

Multiple HTTP GET requests targeting a “CustomerEmail.txt” file were observed, with all attempts originating from the unknown source IP 10.0.0.200. These repeated requests correspond with observed Shellshock exploitation attempts, suggesting the attacker(s) may have been abusing the web server’s CGI components. Shellshock allows remote code execution on vulnerable Bash environments. This pattern represents suspicious and potentially malicious activity aimed at the LAMP server.

Affected Assets:

- Lamp Stack
- Customer data
    - E.g. emails

Discovery Method:

- Web server Get/Request logs via Wazuh
- Web server suspicious activity alerts via Wazuh

Evidence:

- Repeated GET requests for “CustomerEmail.txt” from 10.0.0.200
- HTTP 403 Forbidden responses associated with those requests
- Wazuh Shellshock attack attempt logs

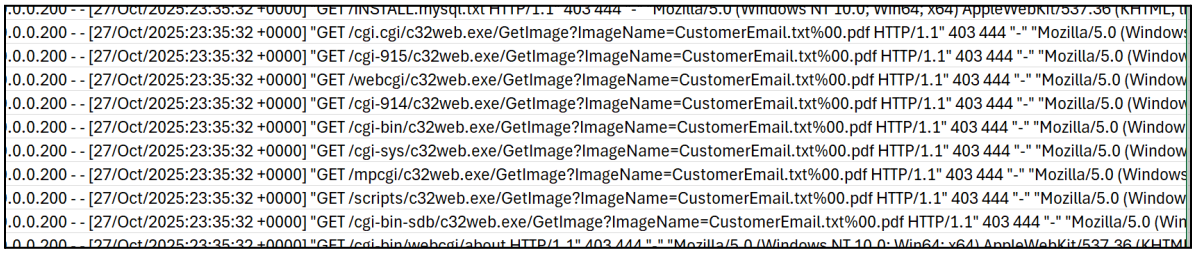

Figure 2.5

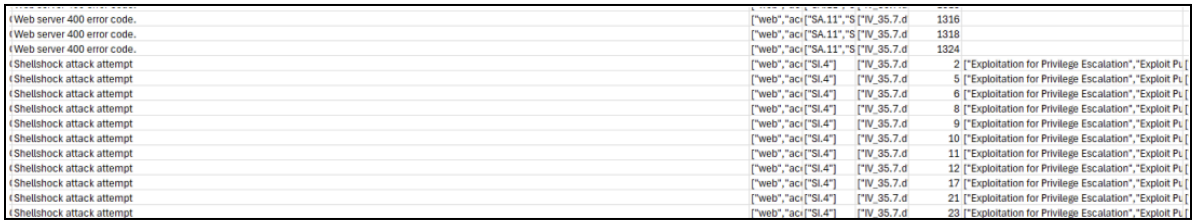

Figure 2.6

Risk Assessment

Finding I — User Specific

Severity Level: Critical

Risk Score: 8

Likelihood of Exploitation: High

- Observed log patterns and known threat behaviors strongly suggest active misuse of privileged credentials. The attacker is already inside the environment and performing privilege escalation.

Potential Impact

- Lateral movement across systems
- Data breach: Attacker can exfiltrate data
- Persistence: Attacker ensures access to the system by adding "ANONYMOUS LOGIN" into the systems
- Full Domain Compromise: Attacker can modify user, group, and policy

Finding II — Service/Application Specific

Severity Level: Critical

Risk Score: 9

Likelihood of Exploitation: High

- Repeated creation of random services and crash-restart behavior reflects strongly on active attacker persistence.

Potential Impact

- Persistence: Attacker maintains access to both domain controllers
- Lateral Movement: Malicious services can execute remote commands
- Privilege Escalation: LocalSystem permission allows modification of security tools and registry settings

Finding III — LAMP - Specific

Severity Level: High

Risk Score: 9

Likelihood Exploitation: High

- Repeated GET requests from the same external IP and Shellshock pattern strings indicate persistence and attempts to exploit the vulnerability.

Potential Impacts:

- Data Exposure: Sensitive web files may be accessed or extracted
- Remote Code Execution: Successful Shellshock exploitation would allow full command execution on the LAMP server.
- Lateral Movement: A compromised web server could be used to pivot deeper into the internal network.

MITRE ATT&CK Mapping

Initial Access

T1190 - Exploit Public-Facing Application

- Shellshock allows remote command execution on vulnerable web servers.

T1078.002 - Valid Accounts: Domain Accounts

- Event IDs: **4624, 4634**
- Anonymous authentication indicates misuse of built-in or misconfigured credentials to gain access. Attackers use anonymous or trusted identities to blend into normal activity and avoid detection.

Privilege Escalation

T1098.007 - Account Manipulation: Additional Local or Domain Groups

- Event ID: **4728**
- Modifying group memberships to gain or retain elevated privileges.

Defense Evasion

T1484.001 - Domain or Tenant Policy Modification: Group Policy Modification

- Event ID: **4737**
- Prevents administrators from reclaiming control by weakening domain security posture.

Command and Control

T1071.001 - Application Layer Protocol: Web Protocols

- Possible C2 traffic disguised as normal web or service activity.

Discovery

T1083 - File and Directory Discovery

- Repeated requests suggest probing for sensitive files.

Persistence

T1543.003 - Create or Modify System Process: Windows Service

- Event ID: **7045**
- Malicious services configured to start automatically under LocalSystem, providing full system-level privileges.

T1547.007 - Boot or Logon Autostart Execution: Re-opened Applications

T1055 - Process Injection

- Event: **AppCrash (win32calc.exe)**
- Frequent crashes may indicate injected or unstable malicious code. Restart behavior may be used to maintain malicious execution.

Recommendations

Immediate Containment

- Isolate DC1 and DC2 from the network immediately to prevent further damage.
- Block traffic from suspicious internal IP 10.0.0.200.
- Remove “ANONYMOUS LOGON” from all privileged groups.
- Reset all privileged domain credentials (Administrator, Domain Admins)
- Review and delete all unauthorized/unknown services.
- Validate integrity of registry keys associated with services.

- Patch Bash to eliminate Shellshock vulnerability.

Long-term Improvements

- Enforce MFA on all administrative accounts.
- Implement complex password and lockout policies.
- Increase monitoring on startup folders, registry Run keys, and scheduled tasks.

Policy & Training Improvements

- Create or update incident response plan.
- Document privileged access procedures.
- Train IT staff on detecting account manipulation.
- Run phishing simulations and awareness training.w